Brim Financial Deep-Dive Audit Report

Date: 2026-03-28

Color Legend

Label	Meaning
RED	High-priority issue. Material governance, privacy, accessibility, or public-trust risk.
AMBER	Meaningful weakness or aging control that should be remediated.
GREEN	Positive control or verified strength.
BLUE	Informational, verified context, or scope limitation.

Executive Summary

This was a passive audit of:

1. The public surface of `brimfinancial.com` and directly related public hosts.
2. The local workspace at `/Users/tarique/Documents/New project`, which is not Brim's production application repository.

No critical remote exploit was validated. The strongest risks are not "obvious hack" findings. They are privacy, legal-document control, accessibility, legacy-host hygiene, and evidence-packaging gaps around public trust and compliance claims.

Domain Scorecard

Domain	Rating	Confidence	Bottom line
Privacy and legal governance	RED	High	The live privacy page and legal-hub documents are out of sync, and homepage tracking behavior is not cleanly aligned with visible consent UX.
Public-surface security	AMBER	High	The main site is fairly hardened, but `pin.brimfinancial.com` looks legacy and `www` still downgrades once to HTTP.
Accessibility	RED	High	`pa11y` reproducibly found 46 errors on the homepage and 44 each on `/privacy` and `/security`.
Compliance claim substantiation	AMBER	Medium	RPAA registration is supported by the Bank of Canada API, but PCI, SOC 2, and ISO claims were not independently proven with artifacts in this audit.
Local codebase	BLUE	High for observed scope	The local workspace is low-risk static collateral and dashboard code, not Brim's application estate.
Technology age and replacement pressure	AMBER	High	The public site mixes current-enough foundations with several stagnant or legacy frontend libraries that should be retired over time.

Self-QA And Corrections

This report includes a deliberate second-pass QA of its own claims.

- An earlier draft overstated an RPAA / PSP-registry mismatch because the Bank of Canada registry page shell says `There are currently no entries` before client-side data loads. The underlying API is the better source. The current API response includes `Brim Financial Inc.` under `accounts.registered` with `registration_date` `2025-10-17`. This report uses that corrected interpretation.
- `pa11y` exits non-zero when it finds accessibility issues. I normalized that behavior and re-parsed the JSON outputs so the counts reported here reflect actual findings, not command-exit confusion.
- No exploit claims are made here without direct validation. Several findings are governance and representation issues rather than exploitation proof.

Confidence Scale

- High: directly observed and repeatable from live headers, page source, API responses, extracted documents, local files, or automation output.
- Medium: strongly supported, but partly dependent on interpretation, package ecosystem context, or indirect evidence.
- Low: plausible inference that still needs internal validation.

Scope And Limits

- Passive checks only. No brute force, authenticated testing, exploit attempts, intrusive scanning, or rate-heavy probing.
- The local workspace is not a git repo and does not contain backend services, infrastructure code, CI/CD config, or Brim's production application source.
- Code conclusions therefore apply only to the provided workspace artifacts, not to Brim's internal application estate.
- Public compliance claims were compared against public artifacts only. I did not obtain auditor-issued reports, certificates, or private evidence packs.

Methods

Public-Surface Review

- HTTP, redirect, cookie, and header checks with `curl`
- DNS and host checks with `dig`
- TLS capability checks with `openssl s_client`
- Public document extraction with `pdftotext`

Runtime Validation

- Browser verification with Playwright
- Network and console review to see what happens before user interaction

Accessibility QA

- Automated WCAG 2 AA spot-checks with `npx --yes pa11y`
- Re-ran checks on `/`, `/privacy`, and `/security`

Historical And Representation Review

- Wayback CDX queries and archived page fetches
- Comparison of current trust-language to older snapshots

Local Workspace Review

- Static review of:
  - [dashboard.html](/Users/tarique/Documents/New project/dashboard.html)
  - [dashboard.js](/Users/tarique/Documents/New project/dashboard.js)
  - [dashboard.css](/Users/tarique/Documents/New project/dashboard.css)
- Review of generated slide-text exports and collateral in `/Users/tarique/Documents/New project/tmp/`
- Secret-pattern grep and code-hygiene review

Verified Positives

- **GREEN** The main site sends HSTS preload, CSP, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, and COOP.
- **GREEN** Main-site TLS is valid through `2026-08-14`.
- **GREEN** CSP blocked the attempted Statcounter beacon during the tested homepage session.
- **GREEN** No secrets or credentials were found in the local workspace.
- **GREEN** The Bank of Canada API currently supports Brim's public RPAA registration claim.

Findings

F1. Public privacy and legal notices are not under clean version control

Rating: **RED**
Confidence: High
Area: Legal / privacy governance

Why this is an issue:

- Public-facing notices should have one clear canonical version.
- Version drift creates avoidable regulatory, procurement, complaint-handling, and litigation risk.

Evidence:

- `https://brimfinancial.com/privacy` contains `Last Updated: November 14, 2025`.
- `https://brimfinancial.com/legal` links the Privacy Policy entry to `https://static.brimfinancial.com/brim//pdf_files/brim-privacy-policy-2018-06-01.pdf`.
- Extracted text from that PDF contains `Last Updated: June 1, 2018`.
- The legal hub also links `Website-terms-of-use-April-1-date1.pdf`, whose extracted text ends with `April 1, 2018`.
- The legal page uses `href="#"` for major legal documents and stores the actual document URLs in custom `link=` attributes, which is weak document delivery and not ideal for accessibility or auditability.

What it means:

- Users can reach multiple official-looking legal/privacy artifacts with different dates and unclear authority.
- Even if Brim's internal privacy program is sound, the public evidence trail is not.

Recommended action:

1. Remove or replace stale legal-hub PDFs immediately.
2. Choose one canonical public privacy-policy source and retire the competing version.
3. Make legal-document links normal accessible links, not `href="#"` placeholders with JS indirection.
4. Add publication controls so legal and privacy content update together.

F2. `pin.brimfinancial.com` presents as a legacy public surface

Rating: **AMBER**
Confidence: High
Area: External security posture

Why this is an issue:

- A weaker secondary hostname can become the real attack path even if the main marketing site is well hardened.
- Legacy disclosures erode confidence during customer due diligence.

Evidence:

- `dig +short pin.brimfinancial.com A` resolved to `209.171.76.159`.
- `curl -sSI https://pin.brimfinancial.com/` returned:

- `Server: Apache/2.4.6 (Red Hat Enterprise Linux) OpenSSL/1.0.2k-fips mod_fcgid/2.3.9 mod_wsgi/3.4 Python/2.7.5`
- no HSTS header on the tested HTTPS 404 response

- `openssl s_client -tls1_3 -connect pin.brimfinancial.com:443 -servername pin.brimfinancial.com` failed with `alert handshake failure`.
- `openssl s_client -tls1_2 ...` succeeded and presented a valid `*.brimfinancial.com` certificate.

What it means:

- Passive evidence does not prove exploitable weakness.
- It does show that a public Brim hostname looks materially older and less consistently hardened than the apex site.

Recommended action:

1. Confirm ownership and business purpose of `pin.brimfinancial.com`.
2. If still needed, move it onto the same edge standard as the apex site.
3. If not needed, retire or restrict it from public exposure.

F3. `www` canonicalization still includes an HTTPS-to-HTTP downgrade hop

Rating: **AMBER**
Confidence: High
Area: Edge / transport hygiene

Why this is an issue:

- Financial domains should not introduce unnecessary transport ambiguity.
- Non-browser clients, bots, and validators still see the downgrade even if browsers recover safely.

Evidence:

- `curl -sSI https://www.brimfinancial.com/` returned `301 Location: http://brimfinancial.com/`.
- The next hop restores HTTPS, but only after the HTTP hop.

What it means:

- This is probably not catastrophic because HSTS exists.
- It is still sloppy edge behavior for a financial-services brand.

Recommended action:

1. Redirect `https://www.brimfinancial.com/` straight to `https://brimfinancial.com/`.
2. Re-test the whole redirect chain, including sitemap and canonical URLs.

F4. Homepage analytics and visible consent controls are inconsistent

Rating: **AMBER**
Confidence: High
Area: Privacy / consent / frontend governance

Why this is an issue:

- The privacy page says Brim seeks additional consent for certain cookie categories where required by law.
- The live homepage still initializes tracking-related code before any visible consent choice appears.

Evidence:

- Homepage source includes:
  - `const API_URL = "https://cookietracker.brim.ca/cookie_tracking/endpoint.php";`
  - `const session_id = "...";`
  - `const ip_address = "...";`

    - `https://www.statcounter.com/counter/counter.js`
    - `//c.statcounter.com/11682868/0/857c09fc/1/`
- The homepage source also contains `<!-- Cookie popup disabled -->` and comments out the consent block around `#cookie_popup`.
- Playwright network capture before any user interaction showed an attempted request to `https://c.statcounter.com/t.php?...`, which failed due to CSP.
- The console confirmed the block came from CSP, not from consent gating logic.

What it means:

- In the tested session, CSP reduced impact by blocking the outbound Statcounter beacon.
- That is still not the same thing as clean consent governance.
- The runtime story is: tracking initializes, the consent UI is hidden/commented, and CSP happens to save part of the day.

Recommended action:

1. Disable non-essential analytics until explicit consent is captured where required.
2. Remove inline exposure of `ip_address` and similar tracking-related values unless there is a compelling need.
3. Rebuild the cookie/consent path so policy text, UI, and runtime behavior actually match.

F5. Accessibility posture is weak on the tested public pages

Rating: **RED**
Confidence: High
Area: Accessibility / public compliance

Why this is an issue:

- Accessibility defects on marketing, legal, and trust pages create inclusion risk and can trigger procurement or legal scrutiny.
- These are public pages, so the issues are easy to reproduce.

Evidence:

- `pa11y` returned:
    - homepage: `46` errors
    - `/privacy`: `44` errors
    - `/security`: `44` errors
- Reproducible issue classes included:
    - duplicate `id` values such as `#navbar` and repeated menu IDs
    - linked images without useful text alternatives
    - a form without a submit button on the homepage
    - insufficient contrast on at least one interactive control
- `curl -sSI https://brimfinancial.com/accessibility` returned `404`.

What it means:

- This is not a one-page typo. The same patterns appear across multiple public pages.
- Automated scanning is not full legal compliance testing, but it is strong evidence of a weak baseline.

Recommended action:

1. Fix duplicate IDs first because they cascade into multiple assistive-technology issues.
2. Repair linked-image alt text and form semantics.
3. Add an accessibility statement or contact path if public-facing accessibility support is expected.
4. Add accessibility automation to publishing or QA workflows.

F6. No public `security.txt` or clearly discoverable disclosure path was found

Rating: **AMBER**
Confidence: High
Area: Security operations / external reporting

Why this is an issue:

- Security researchers, customers, and partners benefit from a standard disclosure route.
- Lack of a clear disclosure path increases friction and slows responsible reporting.

Evidence:

- `https://brimfinancial.com/.well-known/security.txt` returned `404`.
- I did not find a clearly labeled security-reporting contact on the reviewed pages.

What it means:

- People have to guess whether to email support, privacy, or partnerships.

Recommended action:

1. Publish a minimal `security.txt`.
2. Add a dedicated security reporting contact or disclosure policy on the security page.

F7. Anonymous public pages create server-side session state, and first-party session cookies do not declare `SameSite`

Rating: **AMBER**
Confidence: High
Area: Session hygiene

Why this is an issue:

- Anonymous public pages do not always need server-side session state.
- Unnecessary session cookies widen the privacy and attack surface.

Evidence:

- Anonymous GET requests to `/`, `/privacy`, `/legal`, and `/security` set `PHPSESSID=...; path=/; secure; HttpOnly`.
- The tested `PHPSESSID` cookie did not include an explicit `SameSite` attribute.

What it means:

- Modern browsers may still default to `Lax`, but explicit behavior is easier to reason about and audit.
- This may be harmless implementation baggage, but it is worth cleaning up.

Recommended action:

1. Confirm whether public anonymous PHP sessions are truly needed.
2. Set an explicit `SameSite` value if the cookie must remain.
3. Remove session creation on static public pages if there is no real requirement.

F8. Public compliance claims are partly corroborated, but most are still claims without public proof artifacts

Rating: **AMBER**
Confidence: Medium
Area: Security assurance / due diligence

Why this is an issue:

- Trust pages and sales collateral are strongest when they link to current proof, not just assertions.

- Due-diligence friction rises when claims cannot be tied to dates, scopes, or issuers.

What is verified:

- `https://brimfinancial.com/security` states that Brim is a registered PSP under the RPAA.
- The Bank of Canada API at `https://www.bankofcanada.ca/rps-api/cif2/accounts/list` currently includes:
  - `en_legal_name` : `Brim Financial Inc.`
  - `status` : `Registered`
  - `registration_date` : `2025-10-17`

What is not independently verified here:

- SOC 2 Type 2
- PCI DSS 4.0 or 4.0.1
- ISO 27001 certification scope, certificate number, validity dates, or issuer metadata

What it means:

- RPAA registration is supported by an official source.
- The rest of the assurance posture may still be accurate, but this audit did not obtain direct proof artifacts.

Recommended action:

1. Build a small public or customer-shareable evidence pack.
2. For each claim, provide date, scope, issuer, and current status metadata.
3. Distinguish between public marketing claims and evidence-backed assurance statements.

F9. Historical review shows the current trust-and-compliance messaging is newer than the page itself

Rating: **BLUE**
Confidence: High
Area: Change control / representation history

Why this matters:

- Evolving trust language is normal.
- As claims become more ambitious, the evidence and publication controls need to become stronger too.

Evidence:

- Wayback CDX results show `/security` existed by 2020.
- The archived `2020-08-20` snapshot still used older wording such as `PCI-DSS compliance and 2048 bit SSL encryption`.
- The archived version did not show the newer RPAA, SOC 2, Coalfire, or ISO language now present.

What it means:

- The page's trust narrative has materially expanded over time.
- That makes document control and proof artifacts more important, not less.

Recommended action:

1. Keep a dated change log or internal approval trail for trust-page changes.
2. Tie new trust-language releases to evidence artifacts and owner approval.

F10. The public frontend stack mixes healthy core libraries with several legacy or stagnant dependencies

Rating: **AMBER**
Confidence: High
Area: Frontend engineering / maintainability

Why this is an issue:

- Legacy libraries often survive long after their original need disappears.
- They increase compatibility debt, accessibility risk, bundle weight, and migration cost.

Observed on the homepage:

- `jQuery v3.7.1`
- `Bootstrap v5.3.2`
- `jQuery Migrate v3.4.1`
- `bootstrap-select v1.14.0-beta3`
- `slick v1.9.0`
- `fancyBox v3.5.7`
- `jquery.nicescroll v3.7.6`
- `WOW v1.1.2`
- `Stickyfill v2.0.4`
- `animate.css` 2015-era build
- `AOS` present
- `Font Awesome 6.4.2`

What it means:

- Core foundations are not wildly outdated, but the experience layer contains several libraries that look stagnant, redundant, or retirement-worthy on a modern marketing site.
- `jQuery Migrate` strongly suggests compatibility debt.
- `bootstrap-select` is a beta build, which deserves intentional review.
- `slick`, `nicescroll`, `WOW`, `Stickyfill`, and the old `animate.css` build all create replacement pressure.

Recommended action:

1. Remove `jQuery Migrate` after testing plugin compatibility.
2. Replace `slick` with a modern carousel approach or CSS scroll-snap if only simple sliders are needed.
3. Retire `jquery.nicescroll`; custom scroll plugins are often accessibility-negative.
4. Replace `WOW` and older animation helpers with native CSS or `IntersectionObserver`.
5. Reassess whether `Stickyfill` is still needed for current browser support targets.
6. Review whether `bootstrap-select` beta behavior is required; if not, move to stable or native accessible selects.

F11. Public trust pages contain small but telling metadata-quality issues

Rating: **BLUE**
Confidence: High
Area: Content hygiene / change control

Why this matters:

- These are not headline vulnerabilities.
- They are still useful signals of how carefully public trust content is maintained.

Evidence:

- The security page includes invalid JSON-LD dates such as `2018-07-39T09:28:00+00:00`.
- The same structured data still includes legacy `http://www.youtube.com/...` URLs in some fields.

What it means:

- The trust page appears to have accumulated content over time without fully refreshing old metadata structures.

Recommended action:

1. Validate structured data in CI or publishing QA.
2. Clean up invalid dates and legacy `http://` references.

F12. French-language trust and privacy surfaces are materially older than the English versions

Rating: **RED**
Confidence: High
Area: Privacy / legal / localization governance

Why this is an issue:

- This is not archive-only drift. These French pages are still live and linked from the current French site.
- For a Canadian financial-services company, bilingual inconsistency on privacy and security pages is a real governance and customer-trust problem.

Evidence:

- `https://brimfinancial.com/fr/privacy` is live, linked from the French site, and states `Derniere mise a jour : 1 juin 2018`.
- `https://brimfinancial.com/fr/security` is live, linked from the French footer, and still says Brim protects sensitive data with `PCI DSS` and `SSL 2048-bit` language rather than the newer English RPAA / SOC 2 / ISO framing.
- `https://brimfinancial.com/fr/legal` still links older French PDF artifacts including:
  - `Brim French Privacy Policy - June 1.pdf`
  - `WebsitetermsofuseApril1date_FR.pdf`
  - older French cardmember agreement variants alongside newer 2024 files

What it means:

- English and French users are not seeing the same trust, privacy, or legal posture.
- This looks like a parallel stale publication track, not a one-off typo.

Recommended action:

1. Audit the full French surface against the English surface page-by-page.
2. Decide which French documents are current and retire the obsolete ones.
3. Add bilingual release controls so English and French trust/legal changes ship together.

F13. Public content surface is broader than the sitemap suggests

Rating: **AMBER**
Confidence: High
Area: Content inventory / public-surface governance

Why this is an issue:

- Public inventory should be intentional, especially for trust, activation, legal, and partner surfaces.
- When discoverable pages are missing from the sitemap, it becomes harder to manage indexing, retention, QA, and review.

Evidence:

- The public sitemap contains `66` URLs.
- In the href-based internal-link graph built from sitemap pages, I did not find clean zero-inlink sitemap pages.
- I did find `59` internal href-linked URLs that were not present in the sitemap, including examples such as:
  - `/PaymentsCanada`
  - `/BankofCanada`
  - `/Womenofinfluence`
  - `/Brimi80`
  - `/aite-novarica`
  - `/fr/privacy`

- `/fr/security`
- `/sbc/activation`

What it means:

- The problem is less "classic orphan sitemap pages" and more "incomplete or unmanaged public inventory."
- Some of these pages may be intentional campaign or PR pages, but the public estate is larger than the sitemap advertises.

Recommended action:

1. Build a canonical URL inventory across HTML pages, PDFs, viewer endpoints, and localized variants.
2. Decide which pages should be in the sitemap, which should be `noindex`, and which should be retired.
3. Treat activation and legal-adjacent flows as high-governance inventory items, not just marketing pages.

F14. Legacy PDFs and PDF-viewer endpoints remain publicly discoverable outside the current primary document set

Rating: **AMBER**
Confidence: High
Area: Document sprawl / legacy content risk

Why this is an issue:

- Old PDFs tend to preserve outdated legal, pricing, product, or insurance language long after current pages move on.
- Search-indexed viewer endpoints create more stale URLs for users, auditors, and customers to encounter.

Evidence:

- Search surfaced a live older PDF:
  - `https://brimfinancial.com/pdf_files/Brim-RewardsTC-EN-Quebec-Aug1-2019.pdf`
  - it still returns `200` and `Last-Modified: Thu, 01 Aug 2019`
- Search also surfaced a legacy viewer pattern such as:
  - `https://brimfinancial.com/pdf/web/viewer.php?pdf=...`
  - following the current redirect chain ends at `https://brimfinancial.com/pdf/web/viewer?...` and returns `404`
- Another public PDF remains live on a static host:
  - `https://static.brimfinancial.com/carp/pdf_files/brim_mastercard_en.pdf`
- The current legal pages already expose many direct PDF assets through custom `link=` attributes rather than a cleaner document-management approach.

What it means:

- Public PDF inventory appears to have grown over time without a strong retirement or deindexing process.
- Even when a viewer URL is now broken, it can remain searchable and create a confusing stale surface.

Recommended action:

1. Inventory every public PDF and viewer endpoint, including static-host variants.
2. Retire or redirect obsolete PDFs to current canonical documents.
3. Deindex or remove broken viewer endpoints and legacy campaign-specific file paths.

F15. At least one live internal link currently points to a `404`

Rating: **AMBER**
Confidence: High
Area: Dead links / content QA

Why this is an issue:

- Dead links on public partner or sales pages weaken credibility and suggest weak content QA.

- A dead linked partner page can also hide stale messaging or retired commercial relationships.

Evidence:

- `https://brimfinancial.com/platform-partners` currently links to `https://brimfinancial.com/manulife-platform`.
- `https://brimfinancial.com/manulife-platform` currently returns `404`.
- The same `platform-partners` page also links to `https://brimfinancial.com/payfacto-us-ca-platform`, which still returns `200`, so this is not just a generic partner-section pattern.

What it means:

- At least one public internal link is broken on a live page.
- There may be more, but this one is directly verified.

Recommended action:

1. Fix or remove the broken `manulife-platform` link immediately.
2. Add automated link checking to publish or regression workflows.
3. Review partner and press pages for retired relationships or stale campaign content.

F16. `feature_animation.js` ships a live `window.starlingbank` configuration object on Brim pages

Rating: **RED**
Confidence: High
Area: JavaScript code quality / third-party data leakage / dead code

Why this is an issue:

- A Brim public asset should not be shipping what appears to be a competitor's application configuration to every visitor.
- This is not just branding debris. The file exposes real environment-specific values and a helper that returns them at runtime.
- Any first-party or third-party script running on the page can read the object directly.

Evidence:

- `https://static.brimfinancial.com/brim/js/feature_animation.js?ver=20260312G` begins with:
  - `window.starlingbank = { config: { ... } }`
  - `workableId: '71732'`
  - `appIntentProtocol: 'starlingbank://'`
  - `businessFormUrl: 'https://registration.starlingbank.com/api/v1/business-subscribers'`
  - `emailVerificationUrl: 'https://registration.starlingbank.com/api/v1/email-verification/'`
  - `instanaTrackingId: 'rhlFFhNZRX-bJNlIHC3Dhw'`
- The same file defines:
  - `window.starlingbank.config.starlingbank = window.starlingbank.config.www;`
  - `window.starlingbank.getConfig = function (item) { ... }`
- The file is included on the public pages I verified:
  - homepage
  - `/about-us`
  - `/signup`
- The lookup logic falls back to the `www` config when the current hostname does not match a known Starling subdomain, so on `brimfinancial.com` the public page still resolves Starling `www` values.

What it means:

- I did not validate that these values are credentials in the narrow sense.
- I did validate that Brim is publicly serving a Starling-branded runtime config object containing production and demo URLs, IDs, and environment selectors.

- That is a concrete code hygiene and third-party data-governance problem, and it is hard to explain away as intentional on Brim's site.

Recommended action:

1. Remove the entire `window.starlingbank` block from `feature_animation.js`.
2. Audit the file for other imported template logic that does not belong to Brim.
3. Review how this asset entered Brim's build or CDN path.
4. Consider notifying the affected third party because their environment metadata is being publicly redistributed by Brim.

F17. `/signup` still uses inline `document.write()` ad-pixel injection and legacy marketing pixels

Rating: **AMBER**
Confidence: High
Area: JavaScript quality / privacy / legacy marketing code

Why this is an issue:

- `document.write()` is legacy, brittle, and generally a sign of old vendor-tagging practices.
- This page already has privacy-governance concerns, so extra legacy ad-tech on a signup flow deserves scrutiny.

Evidence:

- `https://brimfinancial.com/signup` contains multiple inline `document.write()` calls that inject:
  - `https://ad.doubleclick.net/ddm/activity/...`
  - `https://pubads.g.doubleclick.net/activity...`
- The same section also includes:
  - Dianomi pixel
  - Krux beacon
- The conversion-pixel comments on the page include historical markers such as `Creation Date: 02/07/2019`.

What it means:

- This is confirmed live on `/signup`.
- I did not find the `document.write()` logic inside `custom.js`; the issue is inline page markup, not the shared `custom.js` bundle itself.
- This is more of a privacy / maintainability / legacy-tagging issue than a direct exploit finding.

Recommended action:

1. Remove `document.write()`-based tracking from `/signup`.
2. Reassess whether each marketing pixel is still needed on a signup flow.
3. Move any remaining required tags into a governed consent-aware tag-management path.

Privacy Deep Dive

The privacy story is the most important non-exploit area in this audit because the site's public policy language, runtime behavior, and legal-document packaging do not line up cleanly.

Topic	What the public policy says	What runtime/source review showed	Assessment
General web analytics	The privacy page says Brim collects IP addresses, browser data, and related activity information for all visitors.	The homepage source exposes `ip_address`, tracking variables, and third-party analytics code.	**BLUE** Disclosed in broad terms, but implementation details are noisier than they need to be.

Consent for certain cookies	The policy says Brim has cookie-related choices and seeks additional consent where required by law.	The visible consent popup is commented out on the homepage, while analytics code still initializes.	**RED** Policy, UX, and runtime do not align cleanly.
Third-party advertising / OBA	The policy discloses use of advertising partners and opt-out routes.	The homepage includes Statcounter and attempted a beacon call before interaction.	**AMBER** Needs a real consent-governance review, even though CSP blocked the tested call.
Cross-border processing	The policy explicitly says data may be maintained or processed in the US or other jurisdictions.	I did not find contradictory evidence.	**GREEN** Public disclosure exists.
Privacy contact path	The policy gives `privacy@brimfinancial.com` and states rights language.	The contact path is visible and consistent on the HTML policy page.	**GREEN** This part is present and clear.
Canonical policy version	The HTML privacy page says `Last Updated: November 14, 2025`.	The legal hub still links a PDF that says `Last Updated: June 1, 2018`.	**RED** This is the clearest privacy-governance failure in the public materials.

Local Workspace Review

Coverage

The local workspace is mostly:

- [dashboard.html](/Users/tarique/Documents/New project/dashboard.html)
- [dashboard.js](/Users/tarique/Documents/New project/dashboard.js)
- [dashboard.css](/Users/tarique/Documents/New project/dashboard.css)
- generated PDFs, images, and slide-text exports in `/Users/tarique/Documents/New project/tmp/`

This is not a production service repository.

Local Code Findings

Rating: **BLUE**
Confidence: High for observed files

Observed:

- No secrets, credentials, auth logic, or backend services were found.
- No network calls or high-risk browser APIs exist in the local dashboard.
- The main forward-looking code issue is XSS hygiene:
  - [dashboard.js](/Users/tarique/Documents/New project/dashboard.js#L367) uses `innerHTML` with locally trusted constants.
  - [dashboard.js](/Users/tarique/Documents/New project/dashboard.js#L437) does the same for action cards.
  - [dashboard.js](/Users/tarique/Documents/New project/dashboard.js#L454) does the same for source cards.

What it means:

- The current workspace is low risk because the data is static and local.
- If those arrays ever become user-controlled or externally sourced, the same code paths become DOM XSS sinks.

Recommended action:

1. Keep the data static or sanitize before interpolation if the dashboard ever becomes dynamic.
2. If this dashboard becomes a maintained app, add lint rules or review guidance against casual `innerHTML` use.

Local Collateral And Proof Risk

Rating: **AMBER**
Confidence: High

The local collateral makes strong assurance claims without bundling proof artifacts in this workspace.

Examples:

- [Brim_Visual_Deck_2026.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Visual_Deck_2026.txt#L69) references `PCI DSS Level 1` and `SOC 2 Type II`.
- [Brim_Pitch_Deck.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Pitch_Deck.txt#L155) through [Brim_Pitch_Deck.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Pitch_Deck.txt#L168) claim PCI scope elimination and no PCI burden for partner institutions.
- [Brim_Reference_Appendix.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Reference_Appendix.txt#L121) references `PIPEDA`, `OSFI`, and `OCC`.
- [Brim_Reference_Appendix.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Reference_Appendix.txt#L471) through [Brim_Reference_Appendix.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Reference_Appendix.txt#L479) reference PCI, SOC 2 Type 2, Coalfire, and ISO 27001:2022.

What it means:

- The dashboard code itself is low risk.
- The higher risk in the workspace is assurance-language management: the claims are stronger than the proof package that accompanies them here.

Technology Age And Replacement Matrix

This matrix focuses on the public site, because the local workspace has no dependency manifest and is mostly plain HTML/CSS/JS.

Component	Observed on public site	Ecosystem signal checked on 2026-03-28	Recommendation
jQuery	`3.7.1`	npm `jquery` latest is `4.0.0`	Keep for now if plugin ecosystem needs it, but plan a controlled jQuery 4 migration rather than indefinite hold.
jQuery Migrate	`3.4.1`	npm `jquery-migrate` latest is `4.0.2`	Treat this as compatibility debt. Remove it after plugin testing.
Bootstrap	`5.3.2`	npm `bootstrap` latest is `5.3.8`	Minor update candidate. Low drama, good hygiene win.
Font Awesome	`6.4.2`	npm `@fortawesome/fontawesome-free` latest is `7.2.0`	Update if icon rendering and licensing are understood. Not urgent, but behind current.
bootstrap-select	`1.14.0-beta3`	npm latest stable is `1.13.18`	Review deliberately. Beta in production deserves a reason. Consider replacing with native accessible controls.
slick	`1.9.0`	npm `slick-carousel` latest is `1.8.1`, package looks stagnant	Replace instead of investing heavily in it.
fancyBox	`3.5.7`	npm `@fancyapps/fancybox` latest is `3.5.7`, package state is old	Fine short term, but consider retirement if only basic lightbox behavior is needed.

jquery.nicescroll	`3.7.6`	npm latest is `3.7.6`, package state is old	Retire. Custom scroll libraries are rarely worth the accessibility tradeoff.
WOW	`1.1.2`	npm `wowjs` latest is `1.1.3`, package state is old	Replace with native CSS or `IntersectionObserver` patterns.
Stickyfill	`2.0.4`	npm `stickyfilljs` latest is `2.1.0`	Likely removable on modern browser baselines. Validate and delete if possible.
animate.css	2015-era build	npm `animate.css` latest is `4.1.1`	Replace or update; current build looks notably old.
AOS	present	npm `aos` latest is `2.3.4`, package state is stagnant	Keep only if it is clearly earning its keep; otherwise consolidate on fewer animation systems.

Highest-Value Actions

1. Fix privacy and legal version drift first. This is the cleanest high-confidence governance issue.
2. Review homepage consent gating and tracking behavior with legal/privacy owners, not just frontend engineers.
3. Audit and synchronize the French trust, privacy, and legal surfaces with the English versions.
4. Triage accessibility errors across `/`, `/privacy`, and `/security`.
5. Review and either modernize or retire `pin.brimfinancial.com`.
6. Fix the `www` redirect so it stays HTTPS-only.
7. Publish `security.txt` and a clearer vulnerability-disclosure contact.
8. Build a full public content inventory covering sitemap pages, unsitemapped pages, PDFs, viewer endpoints, and localized variants.
9. Remove broken links and retire or redirect obsolete PDFs and campaign pages.
10. Build a lightweight evidence pack for RPAA, PCI, SOC 2, and ISO claims.
11. Start retiring stagnant frontend libraries, beginning with `jQuery Migrate`, `slick`, `nicescroll`, `WOW`, and old animation/polyfill code.

Reproduction Notes

These are representative commands used to reproduce the strongest findings:

```
curl -sSI https://www.brimfinancial.com/
curl -sSI https://pin.brimfinancial.com/
echo | openssl s_client -tls1_3 -connect pin.brimfinancial.com:443 -servername pin.brimfinancial.com
curl -sS https://brimfinancial.com/ | nl -ba | sed -n '934,952p'
curl -sS https://brimfinancial.com/ | nl -ba | rg -n 'cookietracker|statcounter|session_id|ip_address'
npx --yes pa11y https://brimfinancial.com/ --reporter json
npx --yes pa11y https://brimfinancial.com/privacy --reporter json
npx --yes pa11y https://brimfinancial.com/security --reporter json
curl -sS https://brimfinancial.com/security | nl -ba | rg -n 'RPAA|SOC 2|PCI-DSS|ISO 27001|Coalfire'
curl -sS https://brimfinancial.com/fr/privacy | nl -ba | sed -n '600,616p'
curl -sS https://brimfinancial.com/fr/security | nl -ba | rg -n 'PCI DSS|SSL|RPAA|SOC 2|ISO 27001'
curl -sS https://brimfinancial.com/platform-partners | rg -n 'manulife-platform|payfacto-us-ca-platform'
curl -sSI https://brimfinancial.com/manulife-platform
curl -sSI https://brimfinancial.com/sbc/activation
curl -sS 'https://static.brimfinancial.com/brim/js/feature_animation.js?ver=20260312G' | nl -ba | sed -n
'1,72p'
curl -sS https://brimfinancial.com/signup | nl -ba | sed -n '912,980p'
curl -sSIL 'https://brimfinancial.com/pdf/web/viewer.php?
```

```
pdf=https%3A%2F%2Fbrimfinancial.com%2Fpdf_files%2Fbrim_world_mastercard_en.pdf%3Fv%3D1.1'
curl -sSI 'https://brimfinancial.com/pdf_files/Brim-RewardsTC-EN-Quebec-Aug1-2019.pdf'
curl -sS https://www.bankofcanada.ca/rps-api/cif2/accounts/list
curl -sS 'https://web.archive.org/cdx/search/cdx?
url=brimfinancial.com/security&output=json&fl=timestamp,original,statuscode,mimetype&filter=statuscode:200&l
```

Evidence References

Public URLs:

- Brim homepage
- Brim privacy page
- Brim French privacy page
- Brim legal page
- Brim French legal page
- Brim security page
- Brim French security page
- Platform partners page
- Legacy SBC activation page
- Shared feature_animation.js asset
- Signup page with inline ad pixels
- Brim privacy PDF linked from legal page
- Brim website terms PDF linked from legal page
- Older rewards PDF still live
- Bank of Canada PSP API
- Wayback CDX API
- Wayback archived security page from 2020-08-20

Local evidence references:

- [dashboard.js](/Users/tarique/Documents/New project/dashboard.js)
- [Brim_Visual_Deck_2026.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Visual_Deck_2026.txt)
- [Brim_Pitch_Deck.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Pitch_Deck.txt)
- [Brim_Reference_Appendix.txt](/Users/tarique/Documents/New project/tmp/slide_texts/Brim_Reference_Appendix.txt)

Bottom Line

My confidence is high that Brim's biggest currently visible issues are privacy/legal content control, stale localized surfaces, public content sprawl, accessibility debt, a legacy-looking secondary host, and aging frontend dependencies on the public site. My confidence is low on any claim about Brim's internal application security maturity because the production codebase, backend, and infrastructure were not present in the provided workspace.